Token-Based Integration on WSO2: Our Implementation

SevaOne takes the Seva Sindhu role. Departments change nothing. WSO2 Identity Server and API Manager carry the token, the callback and the status check.

Service · Request · Event or callback · Data store · Runs on a separate server

1 Users and portal

Citizen
Logs in with OTP or DigiLocker

Assisted-mode operator
Franchise login (K1, B1, G1, AJSK, BSK)

SevaOne web portal
React 19 · Apply button and operator console

log in, apply: HTTPS

2 Edge

NGINX reverse proxy
TLS · routes portal and API traffic

3 SevaOne backend (.NET 10)

Handoff service
Creates the unique edcsApplicationRefNo and asks WSO2 Identity Server for the Token. Builds the auto-submitting POST form: UserId, edcsApplicationRefNo, Token, assistedmode, ServiceId.

Understanding needed: edcsApplicationRefNo format

URL 2 receiver (TokenIntegration controller)
Takes the call that the gateway has already screened. Checks the Token with WSO2 Identity Server, matches it to the stored handoff and the department, saves the payment and acknowledgement once, sets SUCCESS, and answers in the contract's format.

Status service (URL 3 client)
Asks each department or Sakala (GSE) for the status of an application by GSC number, through the gateway.

mint Token

forward + secret

4 WSO2: the integration backbone

WSO2 Identity Server 7.3
Login: citizen, operator and admin issuers (already in place)
Mints the Token: OAuth2 access token for each handoff, with the department and service in its scope. Opaque, single use, 30 minutes.
Introspection: is the Token active, and for which department?
Revocation: the Token is revoked after a successful URL 2 save.
Kill switch: disable a department's account or app, effect is live.

introspect and revoke Token

Basic credentials and accounts kept in WSO2

WSO2 API Manager 4.7
Inbound API: /api/TokenIntegration/department-update, same path and JSON as the contract. Checks Basic credentials, IP allow-list, throttle tier per department and payload size. Stamps the gateway secret.
Outbound APIs: one per department for URL 3. Retry, timeout and throttling live here. Analytics and a department application for each.
Optional: a Token-check API backed by IS introspection.

Understanding needed: how departments check the Token today

Basic auth

POST department-update

5 Department systems (no change needed)

URL 1: Department URL
Accepts the POST form and answers HTTP 200.
No change: this is what Seva Sindhu sends today.

Understanding needed: our server IPs on their allow-lists

Application form and fee
The citizen fills the form and pays on the department's site

Final acknowledgement and URL 2 call
Generates the acknowledgement and posts it with Basic auth.
Calls again if SevaOne answers "Data Not Inserted".

Understanding needed: the address the departments call

URL 3: status check API
Provided by the department, or by Sakala (GSE).
Looks an application up by GSC number.

Understanding needed: its authentication and response

browser POST form: UserId, edcsApplicationRefNo, Token, assistedmode, ServiceId

redirect back to SevaOne with the acknowledgement

outbound status API: retry, timeout, throttle · POST { GscNumber }

save · outbox

cache

events

6 Data and streaming

PostgreSQL 18
Handoffs, token hashes, applications
Payment and acknowledgement records
Status timeline and outbox

Redis 8
Token verdicts, 60 s at most
Data-protection keys

Apache Kafka 4.3
Events: acknowledgement received, status changed